1. INTRODUÇÃO

A transformação digital consolidou-se como um fenômeno irreversível na dinâmica econômica contemporânea, alterando profundamente a forma como organizações de todos os portes operam, comunicam-se e armazenam suas informações. Nesse contexto, as pequenas e médias empresas (doravante PMEs) passaram a depender de forma crescente de sistemas informatizados, plataformas em nuvem e serviços digitais para a condução de suas atividades cotidianas. Essa dependência materializa-se, no dia a dia dessas organizações, em um parque de equipamentos de tecnologia da informação — estações de trabalho, servidores, ativos de rede e dispositivos móveis — que concentra os dados, as credenciais e os processos essenciais ao negócio. Tal dependência, embora amplie a competitividade e a eficiência operacional, expõe essas organizações a um conjunto cada vez mais sofisticado de ameaças cibernéticas, tornando a segurança da informação um elemento central para a sustentabilidade dos negócios.

Diferentemente das grandes corporações, que dispõem de equipes especializadas, orçamentos robustos e estruturas dedicadas à proteção de seus ativos digitais, as PMEs frequentemente operam sob severas restrições de recursos humanos, financeiros e técnicos. Em parques de pequeno porte, a administração dos equipamentos costuma recair sobre um único profissional, sobre um prestador de serviços terceirizado ou sobre o próprio responsável pelo negócio, sem processos formalizados de inventário, atualização e resposta a incidentes. Essa assimetria faz com que tais empresas se tornem alvos preferenciais de agentes mal-intencionados, que exploram a ausência de práticas básicas de proteção para perpetrar ataques como sequestro de dados, fraudes eletrônicas, furto de credenciais e vazamento de informações sensíveis. As consequências desses incidentes ultrapassam os prejuízos financeiros imediatos, podendo comprometer a reputação, a continuidade operacional e a própria existência da organização. Cabe ressaltar que a versão mais recente do framework de cibersegurança do NIST foi concebida para ser aplicável a qualquer organização, independentemente de seu porte, setor ou nível de maturidade (NIST, 2024).

Diante da heterogeneidade que caracteriza o universo das PMEs, adota-se neste trabalho o parque de equipamentos de tecnologia da informação como unidade

de análise, em substituição a critérios exclusivamente econômicos, como faturamento anual ou número de empregados. Entende-se por pequeno parque de equipamentos o conjunto de até 100 dispositivos gerenciados por uma mesma organização, compreendendo: (i) endpoints, isto é, estações de trabalho, notebooks e periféricos corporativos; (ii) servidores locais, tais como servidores de arquivos, controladores de domínio e sistemas de armazenamento em rede; (iii) ativos de rede, incluindo roteadores, switches, firewalls e pontos de acesso sem fio; e (iv) dispositivos móveis corporativos e serviços em nuvem contratados, como correio eletrônico, armazenamento de arquivos e sistemas de gestão empresarial. Essa delimitação justifica-se porque são a dimensão e a composição do parque — e não o porte econômico da empresa — que determinam a superfície de ataque exposta, o esforço técnico exigido para protegê-la e a viabilidade prática de implantação dos controles propostos.

Apesar da gravidade desse cenário, observa-se que grande parte dos referenciais de cibersegurança disponíveis foi originalmente concebida tendo em vista a realidade de organizações de grande porte ou de setores de infraestrutura crítica, pressupondo parques com centenas ou milhares de ativos, equipes segregadas por função e ferramentas de monitoramento contínuo — condições ausentes em ambientes de até 100 dispositivos. A complexidade técnica, a extensão dos controles exigidos e o elevado custo de implementação constituem barreiras significativas que afastam as PMEs da adoção de medidas protetivas adequadas. Justifica-se, portanto, a necessidade de investigar e propor soluções acessíveis, capazes de traduzir as boas práticas de segurança em ações concretas e exequíveis dentro das limitações típicas de parques dessa dimensão, contribuindo para a redução de sua vulnerabilidade e para a democratização do acesso à proteção digital.

Diante desse panorama, apresenta-se o seguinte problema de pesquisa: “quais práticas de segurança básica podem reduzir a vulnerabilidade a ataques cibernéticos em pequenos parques de equipamentos de tecnologia da informação, com até 100 dispositivos gerenciados, mantidos por pequenas e médias empresas?”

Para responder a essa indagação, estabelece-se como objetivo geral identificar e propor práticas de segurança básicas que auxiliem as PMEs a reduzir a vulnerabilidade de seus pequenos parques de equipamentos a ataques cibernéticos, mediante a elaboração de um framework simplificado de segurança e de um modelo de maturidade adaptado a essa escala, capazes de evidenciar as vulnerabilidades

existentes e os passos que devem ser seguidos para o seu aprimoramento. A fim de alcançar esse propósito, delimitam-se os seguintes objetivos específicos:

- Conceituar a cibersegurança e seus pilares fundamentais;
- Caracterizar o pequeno parque de equipamentos de tecnologia da informação, delimitando seu critério de porte e sua composição típica nas PMEs brasileiras;
- Explicar o contexto atual de vulnerabilidade enfrentado pelas PMEs que operam parques dessa dimensão;
- Investigar as principais brechas de segurança comumente exploradas por atacantes nesses parques, relacionando-as às categorias de ativos que os compõem;
- Pesquisar os frameworks de cibersegurança existentes, verificando sua aplicabilidade a parques de pequeno porte;
- Construir um framework simplificado e um modelo de maturidade voltados à redução de riscos cibernéticos em pequenos parques de equipamentos mantidos por PMEs.

Do ponto de vista metodológico, a presente pesquisa caracteriza-se como de natureza aplicada e abordagem qualitativa, configurando-se quanto aos objetivos como exploratória e descritiva. O recorte adotado é o do parque de equipamentos, e não o da empresa isoladamente considerada, de modo que os controles propostos possam ser avaliados em função dos ativos efetivamente existentes no ambiente. O desenvolvimento do trabalho fundamenta-se em pesquisa bibliográfica e documental, a partir da análise de normas e referenciais consagrados no campo da segurança da informação. Entre eles, destacam-se o NIST *Cybersecurity Framework* (CSF) 2.0, que organiza os resultados de segurança em seis funções estruturantes — Governar, Identificar, Proteger, Detectar, Responder e Recuperar (NIST, 2024) — e o *Cybersecurity Capability Maturity Model* (C2M2), que associa a cada prática um nível indicador de maturidade (MIL) responsável por expressar a progressão das capacidades de segurança da organização (DOE, 2022). De maneira complementar, recorre-se às normas ISO/IEC 27001 (ABNT, 2022a) e ISO/IEC 27002 (ABNT, 2022b), que estabelecem, respectivamente, os requisitos de um sistema de gestão da segurança da informação e as diretrizes para a seleção e implementação de controles.

A partir desse levantamento, propõe-se a construção de um modelo de maturidade híbrido, que articula as seis funções do NIST CSF 2.0 como eixo temático

e os níveis indicadores de maturidade do C2M2 como escala de progressão, de modo a oferecer às PMEs um instrumento de avaliação e evolução dimensionado para parques de até 100 dispositivos e compatível com suas reais condições operacionais. Espera-se que a articulação entre os referenciais teóricos e a proposta de um instrumento adaptado contribua para a discussão acerca da segurança digital em ambientes de pequeno porte, oferecendo subsídios práticos para a adoção progressiva de medidas protetivas. Para tanto, o presente trabalho organiza-se de forma a apresentar, ao longo de suas seções, os fundamentos conceituais da cibersegurança, a delimitação e a caracterização do pequeno parque de equipamentos, o diagnóstico do cenário de vulnerabilidade a que ele está exposto, a análise dos frameworks existentes e, finalmente, a proposição do framework simplificado e do modelo de maturidade que constituem o cerne desta investigação.

REFERÊNCIAS ABNT- REVER

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. *ABNT NBR ISO/IEC 27001: tecnologia da informação — técnicas de segurança — sistemas de gestão da segurança da informação — requisitos*. Rio de Janeiro: ABNT, 2022a.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. *ABNT NBR ISO/IEC 27002: tecnologia da informação — técnicas de segurança — controles de segurança da informação*. Rio de Janeiro: ABNT, 2022b.

DEPARTMENT OF ENERGY (DOE). *Cybersecurity Capability Maturity Model (C2M2): version 2.1*. Washington: U.S. Department of Energy, 2022. Disponível em: https://www.energy.gov/ceser/cybersecurity-capability-maturity-model-c2m2. Acesso em: 2 jun. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). *The NIST Cybersecurity Framework (CSF) 2.0*. Gaithersburg: NIST, 2024. Disponível em: https://doi.org/10.6028/NIST.CSWP.29. Acesso em: 2 jun. 2026.